Rapport TP 2.2

Introduction

L'objectif de ce TP est de passer d'une phase de détection de vulnérabilités à une phase active de remédiation afin de durcir la sécurité des systèmes cibles.

Partie 1 : Analyse des vulnérabilités critiques

1. Vulnérabilités Windows

A. Nom de la vulnérabilité, ex: MS17-010 EternalBlue

- **Quel est le problème :** Le protocole SMBv1 présente des failles permettant l'exécution de code à distance.
- **Quel est le risque** : Prise de contrôle totale de la machine, propagation de ransomwares.
- **Comment exploitable :** Via l'envoi de paquets spécialement conçus vers le port 445
- **Capture d'écran (Nessus - Avant correction) :**

ntoguem / Plugin #97833

‹ Back to Vulnerabilities

Vulnerabilities 18

HIGH MS17-010: Security Update for Microsoft Windows SMB Server (4013389) (ETERNALBLUE) (ETERNALCHAM

Description

The remote Windows host is affected by the following vulnerabilities :

- Multiple remote code execution vulnerabilities exist in Microsoft Server Message Block 1.0 (SMBv1) due to improper handling of certain requests. An unauthenticated, remote attacker can exploit these vulnerabilities, via a specially crafted packet, to execute arbitrary code. (CVE-2017-0143, CVE-2017-0144, CVE-2017-0145, CVE-2017-0146, CVE-2017-0148)

- An information disclosure vulnerability exists in Microsoft Server Message Block 1.0 (SMBv1) due to improper handling of certain requests. An unauthenticated, remote attacker can exploit this, via a specially crafted packet, to disclose sensitive information. (CVE-2017-0147)

ETERNALBLUE, ETERNALCHAMPION, ETERNALROMANCE, and ETERNALSYNERGY are four of multiple Equation Group vulnerabilities and exploits disclosed on 2017/04/14 by a group known as the Shadow Brokers. WannaCry / WannaCrypt is a ransomware program utilizing the ETERNALBLUE exploit, and EternalRocks is a worm that utilizes seven Equation Group vulnerabilities. Petya is a ransomware program that first utilizes CVE-2017-0199, a vulnerability in Microsoft Office, and then spreads via ETERNALBLUE.

Solution

Microsoft has released a set of patches for Windows Vista, 2008, 7, 2008 R2, 2012, 8.1, RT 8.1, 2012 R2, 10, and 2016. Microsoft has also released emergency patches for Windows operating systems that are no longer supported, including Windows XP, 2003, and 8.

B. Nom de la vulnérabilité, ex: SMB Signing not required

- **Quel est le problème :** Les communications SMB ne sont pas signées.
- **Quel est le risque :** Interception et modification du trafic (Man-in-the-Middle).
- **Comment exploitable :** Un attaquant sur le même réseau peut usurper le serveur.

ntoguem / Plugin #57608

‹ Back to Vulnerability Group

Vulnerabilities 18

MEDIUM SMB Signing not required

Description

Signing is not required on the remote SMB server. An unauthenticated, remote attacker can exploit this to conduct man-in-the middl
the SMB server.

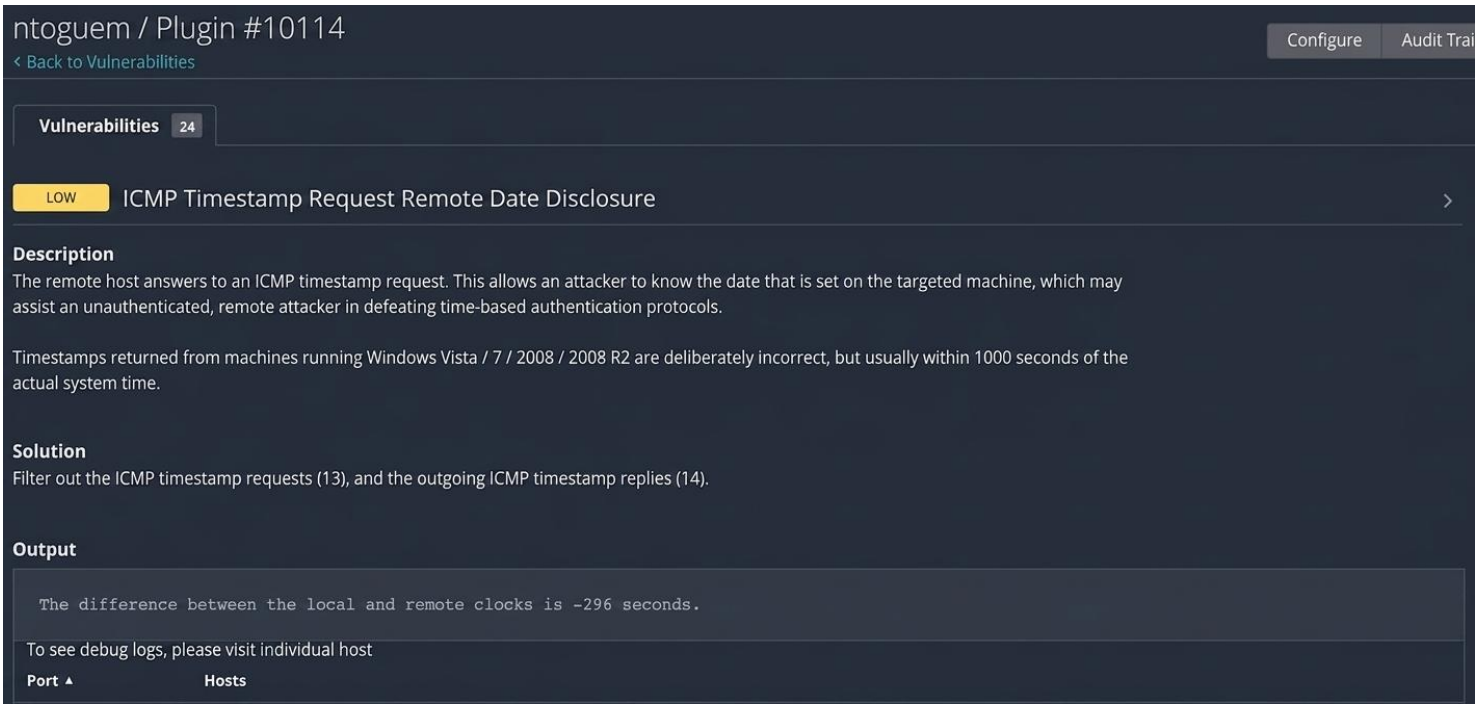
Solution

Enforce message signing in the host's configuration. On Windows, this is found in the policy setting 'Microsoft network server: Digital
communications (always)'. On Samba, the setting is called 'server signing'. See the 'see also' links for further details.

See Also

http://www.nessus.org/u?df39b8b3
http://technet.microsoft.com/en-us/library/cc731957.aspx
http://www.nessus.org/u?74b80723
https://www.samba.org/samba/docs/current/man-html/smb.conf.5.html

2. Vulnérabilités Linux



Vulnérabilité : ICMP Timestamp Request Remote Date Disclosure (Plugin #10114)

- **Quel est le problème ?** La machine répond aux requêtes ICMP de type "Timestamp" (horodatage). Cela permet à n'importe quel attaquant distant d'obtenir l'heure système précise configurée sur votre machine.
- **Quel est le risque ?** Le risque est une **divulgation d'informations**. Bien que jugé "faible", cet accès à l'heure système permet à un attaquant de cartographier plus précisément le réseau ou de tenter de contourner des mécanismes d'authentification basés sur le temps (token temporaires, synchronisation de session, etc.).
- **Comment exploitable ?** Un attaquant envoie un paquet ICMP de type 13 (Timestamp Request) à la machine cible. La machine, par défaut, répond avec un paquet de type 14 (Timestamp Reply) contenant son horodatage interne. Aucun compte utilisateur n'est nécessaire pour effectuer cette requête.

Partie 2 & 3 : Correction et Remédiation

1. Actions sur Windows

- **Commande utilisée pour le pare-feu :** netsh advfirewall set allprofiles state on

2. Actions sur Linux

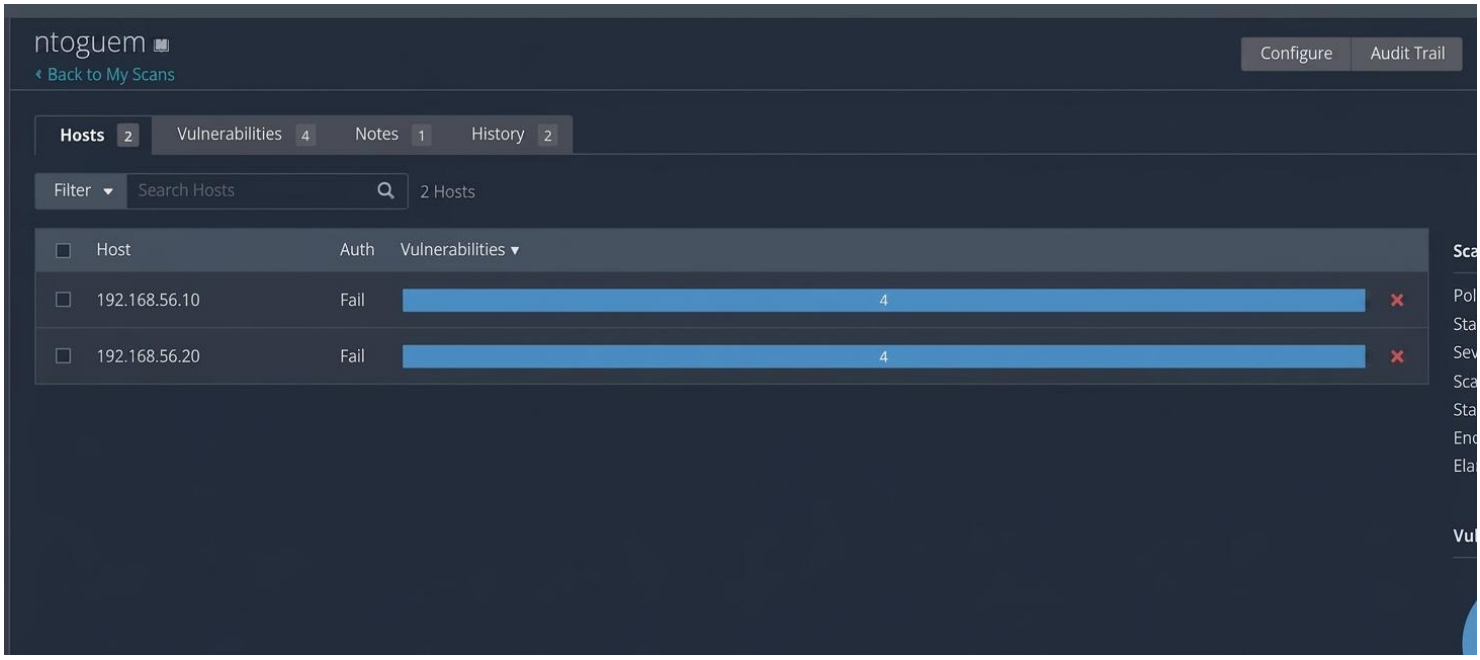
- **Mises à jour :** sudo apt update && sudo apt upgrade -y
- **Configuration pare-feu :** sudo ufw enable

Partie 4 : Re-scan Nessus et Comparaison

Comparaison des résultats

Résultat final (Scan de vérification)

- **Commentaire :** après mise à jour des paquets et activation des pare-feu, on constate qu'il y'a plus aucune vulnérabilité visible.
- **Capture d'écran (Scan Nessus Après correction) :**


ntoguem
Back to My Scans
Configure
Audit Trail
Hosts 2
Vulnerabilities 4
Notes 1
History 2
Filter
Search Hosts
2 Hosts
Host
Auth
Vulnerabilities
192.168.56.10
Fail
4
192.168.56.20
Fail
4